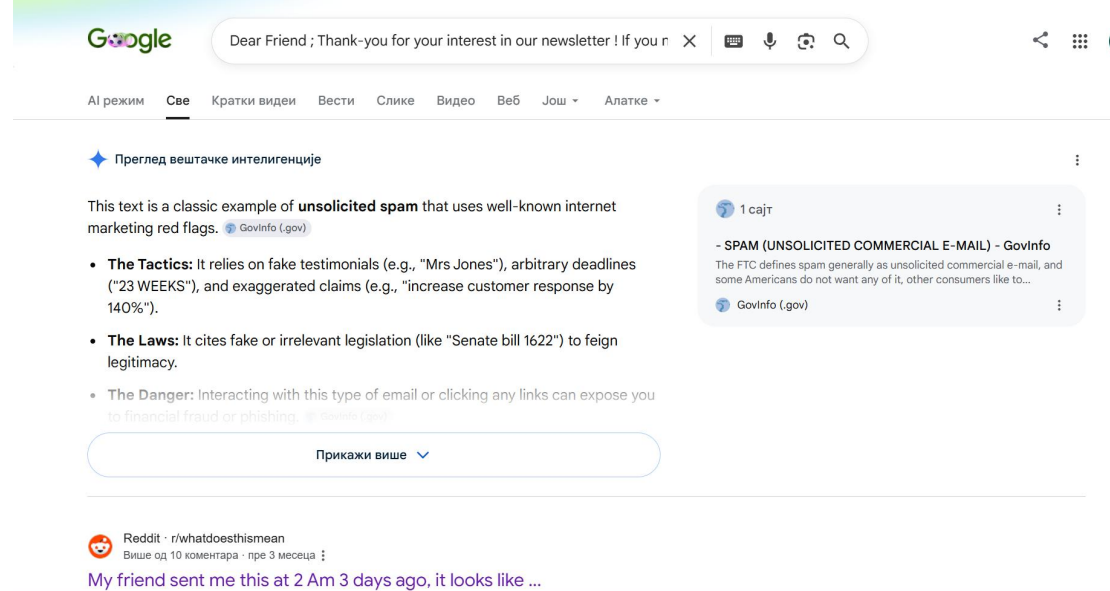


Prvobitna analiza i manuelna pretraga

Nakon čitanja teksta sumnjivog mejla, prvo sam izvršila manuelnu pretragu teksta kako bih proverila da li je flag eksplicitno naveden u nekom delu rečenice ili skriven kao akronim. Tekst je izgledao kao klasična spam poruka i flag nije bio vidljiv na prvi pogled.



OSINT istraživanje preko Google pretraživača

Kopirala sam delove teksta poruke i pretražila ih na Google-u kako bih videla da li se ovaj specifičan šablon pojavljivao ranije:

Prvi rezultat je bio Reddit članak sa identičnim tekstom mejla, ali bez konkretnih smernica za rešenje.

Drugi rezultat je bio stručni rad pod nazivom "*Steganography: What's the Real Risk?*" sa GIAC (SANS) instituta.

<https://www.giac.org/paper/gsec/1461/steganography-real-risk/102743>

inscribed messages on the underlying wood and recovered the tablets with wax so that the sentries would not notice anything unusual during inspection.³ Today, with new technologies and the abundance of processing power available at relatively cheap cost, there have been many tools developed to hide messages in email, embed data in images, and pass information through video and sound.

Tools of the Trade:

SpamMimic⁴

SpamMimic is a process that the people over at <http://spammimic.com/> have developed to encode and decode email messages to be disguised as spam. Considering the amount of Spam that is sent around the internet, and also considering that most people either filter it at the mail server or just delete it, it's really an ingenious idea. This really makes security through obscurity a reality. Let's say some terrorist group wants to coordinate some type of action to its followers in the United States. Using an anonymous email application, or a hacked server for that matter, the message could be sent to a huge mailing list just as any other Spam is done. The people who are expecting the mail could take the Spam-encoded message, and simply decode it. Why not just use PGP or some other encryption software? Mainly because if you are afraid of being monitored, encryption leaves an obvious trail and is easily detected. If you're monitoring traffic, a simple Spam message could easily slip through undetected as it has the form of plain ordinary text. Here's an example using spammimic's site to encode the message:

Gentlemen, the chair is against the wall. John has a long mustache. Thank you.

This message encodes into:

Dear Friend , Your email address has been submitted to us indicating your interest in our newsletter . We will comply with all removal requests . This mail is being sent in compliance with Senate bill 1623 ; Title 3 ; Section 301 . This is a legitimate business proposal ! Why work for somebody else when you can become rich as few as 97 WEEKS . Have you ever noticed people will do almost anything to avoid mailing their bills & nearly every commercial on television has a .com on in it ! Well, now is your chance to capitalize on this . WE will help YOU process your orders within seconds plus SELL MORE . You are guaranteed to succeed because we take all the risk ! But don't believe us . Prof Jones who resides in Washington tried us and says "I was skeptical but it worked for me" ! We assure you that we operate within all applicable laws ! You will blame yourself forever if you don't order now . Sign up a friend and you'll get a discount of 20% . Thank-you for your serious consideration of our offer! Dear Web surfer ; Especially for you - this breath-taking info . We will comply with all removal requests . This mail is being sent in compliance with Senate bill 1626, Title 9 ; Section 305 ! This is different than anything else you've seen . Why work for somebody else when you can become rich as few as 43 MONTHS . Have you ever noticed how many people you know are on the Internet and more people than ever are surfing the web . Well, now is your chance to capitalize on this ! WE will help YOU deliver goods right to the customer's doorstep plus decrease perceived waiting time by 170% . You can begin at absolutely no cost to you ! But don't believe us . Prof Anderson of California tried us and says "My only problem now is where to park all my cars"! We are licensed to operate in all states . For the sake

³ Niel F. Johnson, Steganography, <http://www.jtc.com/stegdoc/stegdoc.html>, Section 2.2

⁴ <http://www.spammimic.com/>

Prepoznavanje alata i dekodiranje

Pomenuti rad je ukazao na to da se spam poruke mogu koristiti za prikrivanje tajnih podataka (Spam-based steganography) i usmerio me na specijalizovani sajt [SpamMimic](http://www.spammimic.com/). Ovaj alat kodira poruke tako da izgledaju kao dosadni spam filterima, ali sadrže skrivenu strukturu.



[Encode](#)
[Decode](#)
[Explanation](#)
[Credits](#)
[FAQ & Feedback](#)
[Terms](#)
[Français](#)

First time here? ... Read the [explanation](#).
Nice to see you're using the secure connection.

Encode

Turn a short message into spam

Decode

Turn spam back into the original message

Copyright © 2000-2025 spammimic.com, All rights reserved

Ekstrakcija flaga

Nalepila sam kompletan tekst imejla u SpamMimic dekode. Alat je uspešno prepoznao šablon, dešifrovao tekst i generisao sakrivenu poruku.

Decoded

Your spam message **Dear Friend ; Thank-you for your interes...** decodes to:

UNS{EM4IL_5P4M_AG4N?}

Encode

Look wrong?, try the [old version](#)

Copyright © 2000-2025 spammimic.com, All rights reserved

UNS{EM4IL_5P4M_AG4N?}